



# LOST BOYS CYBER

THREAT INTELLIGENCE • MALWARE ANALYSIS • DETECTION ENGINEERING



## CVE-2026-8398 DAEMON Tools Lite embedded malicious code supply-chain compromise

CVE / Vulnerability Threat Intelligence Report

|                       |                                                |
|-----------------------|------------------------------------------------|
| <b>Classification</b> | TLP:CLEAR                                      |
| <b>Published</b>      | 2026-05-27                                     |
| <b>Version</b>        | 1.1                                            |
| <b>Author</b>         | Lost Boys Cyber                                |
| <b>Report Type</b>    | CVE / Vulnerability Threat Intelligence Report |

TLP:CLEAR | Lost Boys Cyber | CVE-2026-8398 DAEMON Tools Lite embedded malicious code supply-chain compromise - CVE / Vulnerability Threat Intelligence Report

Published: 2026-05-27 | TLP:CLEAR | Version: 1.1 | Author: Lost Boys Cyber

AI Generation: This report was generated with AI assistance and is provided for informational purposes only. All findings, IOCs, detection rules, hunting queries, attribution assessments, and recommendations must be independently reviewed and validated by a qualified security professional before operational use.

## Table of Contents

1. Executive Summary
2. Vulnerability Metadata
3. Source Review & Confidence
4. Vulnerability Details
5. Attack Scenarios
6. Threat Landscape & Exploitation Status
7. Affected Products and Exposure
8. Mitigation and Workarounds
9. Detection Engineering
10. Threat Hunting
11. MITRE ATT&CK Mapping
12. Validation / Lab Testing
13. Recommended Actions Summary
14. References

# CVE-2026-8398 DAEMON Tools Lite embedded malicious code supply-chain compromise

## 1. Executive Summary

CVE-2026-8398 tracks a malicious-code supply-chain compromise affecting official Windows installers for DAEMON Tools Lite. Public CVE, NVD, and vendor reporting agree that trojanized installers were distributed from the legitimate `daemon-tools.cc` site between approximately 2026-04-08 and 2026-05-05, after attackers interfered with the vendor's build or distribution infrastructure and inserted malicious binaries signed with AVB Disc Soft's legitimate code-signing certificate.

This is not best understood as a classic remotely exploitable product bug. The stronger public evidence supports a trusted-software distribution compromise in which affected installations activated a backdoor, beacons to attacker infrastructure, and enabled follow-on payload delivery from legitimate-seeming software. Because CISA added the issue to KEV on 2026-05-27, organizations that installed affected DAEMON Tools Lite versions during the malicious distribution window should treat those endpoints as potentially compromised and prioritize containment, replacement, credential review, and forensic investigation.

## 2. Vulnerability Metadata

| Field                                                     | Value                                                          |
|-----------------------------------------------------------|----------------------------------------------------------------|
| CVE                                                       | `CVE-2026-8398`                                                |
| Product                                                   | `DAEMON Tools Lite` for Windows                                |
| Weakness                                                  | `CWE-506 Embedded Malicious Code`                              |
| Malicious distribution window                             | approximately `2026-04-08` through `2026-05-05`                |
| Affected versions publicly named by NVD / CVE / Kaspersky | `12.5.0.2421` through `12.5.0.2434`                            |
| Vendor-safe release                                       | `12.6.0.2445` (`12.6`) and newer                               |
| Vendor shorthand for affected branch                      | `12.5.1`                                                       |
| Trojanized binaries                                       | `DTHelper.exe`, `DiscSoftBusServiceLite.exe`, `DTShellHlp.exe` |
| CVSS v4.0                                                 | `9.3 / CRITICAL` (Kaspersky CNA)                               |
| CVSS v3.1                                                 | `9.8 / CRITICAL` (Kaspersky CNA / NVD)                         |
| KEV status                                                | added by CISA on `2026-05-27` with due date `2026-05-30`       |

`CVSS:4.0/AV:N/AC:L/AT:N/PR:N/UI:N/VC:H/VI:H/VA:H/SC:N/SI:N/SA:N`

`CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H`

## 3. Source Review & Confidence

| Source          | Contribution                                                                                                              | Confidence                                                                                  |
|-----------------|---------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------------------------------------------------|
| Primary source  | CISA KEV lists `CVE-2026-8398` as `Daemon Tools Lite Embedded Malicious Code Vulnerability`, records `Date Added: 2026-0` | High-confidence official exploitation-prioritization source and the original intake anchor. |
| Reviewed source | NVD mirrors the CNA description, records `CWE-506`, exposes KEV due-date and                                              | High-confidence canonical vulnerability                                                     |

|                 |                                                                                                                          |                                                                                                      |
|-----------------|--------------------------------------------------------------------------------------------------------------------------|------------------------------------------------------------------------------------------------------|
|                 | required-action fields, and lists critical                                                                               | reference and structured scoring source.                                                             |
| Reviewed source | The CVE Services record published by Kaspersky confirms the affected product, malicious installer distribution window, t | High-confidence CNA-backed CVE record useful for title normalization, affected-version corroboration |
| Reviewed source | Disc Soft acknowledges unauthorized interference in infrastructure, says certain packages from the build environment wer | Official vendor acknowledgement and safe-version source.                                             |
| Reviewed source | Kaspersky reports the trojanized version range `12.5.0.2421` through `12.5.0.2434`, names the three altered binaries, id | Highest-value technical source for payload behavior, infrastructure, and victimology; rely on vendor |

Confidence is high because the core facts align across official and near-primary sources: Confidence is lower on any claim that assumes uniform victim outcomes. Public evidence strongly supports widespread exposure to trojanized installers and selective second-stage deployment, but each organization's actual impact depends on whether affected installers were executed, what privileges those hosts had, and whether follow-on payloads were delivered before containment.

## 4. Vulnerability Details

According to the CVE, NVD, and Kaspersky reporting, the attacker did not exploit a normal feature flaw in DAEMON Tools Lite. Instead, the attacker compromised the trusted software supply chain and modified official installers distributed from the legitimate vendor website. The malicious installers included three trojanized binaries inside the normal installation path, typically `C:\Program Files\DAEMON Tools Lite`, while retaining the vendor's valid code-signing trust.

Kaspersky states the inserted backdoor launched when one of the trojanized binaries started, created a dedicated thread, and sent HTTP GET requests to `https://env-check.daemontools[.]jcc/2032716822411?s=<full computer name>`. If the malicious server returned a command, the host executed `cmd.exe /c powershell -NoProfile -Command ...` to download and run additional payloads from `38.180.107[.]76`. Kaspersky describes multiple follow-on payload classes, including an information collector, a minimalistic backdoor, and a QUIC-based remote-access payload, while noting that only a small subset of infected systems received those later-stage components.

The vendor's incident note materially narrows the currently supported remediation picture: Disc Soft says the compromised files were removed from distribution, affected systems were isolated, and the current `12.6` line was rebuilt and validated after disclosure. That does not eliminate retrospective risk for hosts that installed the poisoned packages during the malicious window.

## 5. Attack Scenarios

1. A user downloads DAEMON Tools Lite from the legitimate vendor website during the malicious distribution window and installs a signed but trojanized package.
2. One of the altered binaries launches during normal product startup, causing beacon traffic to the attacker-controlled `env-check.daemontools[.]jcc` domain.
3. The malicious control server returns a shell command that uses PowerShell to fetch and execute an additional payload from `38.180.107[.]76`.
4. A high-value endpoint such as an engineering workstation, government desktop, or shared enterprise image receives a second-stage payload, enabling broader host reconnaissance, command execution, or later remote-access activity.
5. The organization upgrades DAEMON Tools Lite but fails to investigate hosts that previously ran the compromised installers, leaving a potential post-compromise gap.

This makes the issue especially relevant to organizations that allow end-user utility software on managed Windows systems, have weak application inventory around desktop tools, or support users who downloaded software directly from vendor sites during the exposure period.

## 6. Threat Landscape & Exploitation Status

- CISA placed the issue in KEV on 2026-05-27, which is the clearest public signal that exploitation in the wild is established.
- Kaspersky says it observed several thousand infection attempts across more than 100 countries, but only a dozen systems receiving later-stage payloads, suggesting broad exposure with more selective follow-on targeting.
- Kaspersky further states that the systems receiving later payloads belonged to retail, scientific, government, and manufacturing organizations.
- The same research notes artifacts suggesting a Chinese-speaking threat actor, but the vendor explicitly says it is not yet attributing the incident to any specific third party.
- The attack is strategically notable because the malicious files were signed with the legitimate AVB Disc Soft certificate, reducing the effectiveness of simplistic reputation or signature-trust assumptions.

For defenders, the key takeaway is that this CVE represents a trusted-installer compromise with real-world post-install execution risk, not merely a packaging anomaly or false-positive antivirus event.

## 7. Affected Products and Exposure

Direct exposure is limited to Windows systems that downloaded or installed affected DAEMON Tools Lite packages while the malicious versions were available. The most relevant exposure categories are:

- unmanaged or lightly managed Windows workstations where users downloaded DAEMON Tools Lite directly from the vendor site
- enterprise desktops that allowed installation of `12.5.0.2421` through `12.5.0.2434` during the observed window
- systems where DAEMON Tools Lite was launched after installation, allowing the trojanized binaries to execute
- higher-value endpoints whose users had local administrative rights, broad network reach, or access to sensitive organizational resources

The vendor states that other Disc Soft products such as DAEMON Tools Ultra and DAEMON Tools Pro were not affected, and that currently available DAEMON Tools Lite versions have been validated as safe. Even so, organizations should inventory historical installs rather than relying only on the currently installed version.

## 8. Mitigation and Workarounds

Priority actions supported by the reviewed sources:

6. Identify any host that downloaded or installed DAEMON Tools Lite during the approximate `2026-04-08` to `2026-05-05` window.
7. Uninstall the affected application from suspect systems and replace it with `12.6` / `12.6.0.2445` or later from the official vendor source.
8. Run an up-to-date antivirus or endpoint scan on affected hosts, consistent with the vendor and CVE remediation guidance.
9. Review affected hosts for persistence, suspicious PowerShell use, downloads from `38.180.107[.]76`, and network access to `env-check.daemontools[.]cc`.
10. Conduct targeted forensic review on any host that executed the trojanized binaries, especially if it belonged to an administrator, developer, or sensitive business function.
11. Review authentication and access logs for suspicious downstream activity from exposed endpoints after installation.
12. Tighten software-allowlisting, user-installation controls, and software-inventory visibility for non-essential desktop utilities.

## 9. Detection Engineering

Detection should focus on exposed Windows endpoints and any follow-on payload activity:

| Signal                                                                                                          | Telemetry Source                                           | Analytic Goal                      |
|-----------------------------------------------------------------------------------------------------------------|------------------------------------------------------------|------------------------------------|
| alert on known-affected DAEMON Tools Lite versions, especially `12.5.0.2421` through `12.5.0.2434`, in software | Asset inventory, SBOM, package management, CI/CD telemetry | Find vulnerable builds or packages |

|                                                                                                                                                                                           |                                                   |                                                                            |
|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|---------------------------------------------------|----------------------------------------------------------------------------|
| inventory or EDR telemetry                                                                                                                                                                |                                                   |                                                                            |
| hunt for the trojanized binaries<br>`DTHelper.exe`,<br>`DiscSoftBusServiceLite.exe`, and<br>`DTShellHlp.exe` on systems that installed<br>DAEMON Tools Lite during the exposure<br>window | Asset inventory / service / security<br>telemetry | Identify vulnerable systems, exposure, or<br>suspicious follow-on activity |
| review DNS, proxy, and EDR telemetry for<br>connections to `env-<br>check.daemontools[.]cc`                                                                                               | Asset inventory / service / security<br>telemetry | Identify vulnerable systems, exposure, or<br>suspicious follow-on activity |
| review network and endpoint telemetry for<br>downloads from `38.180.107[.]76`                                                                                                             | Network, auth, proxy, or service-access<br>logs   | Identify externally reachable or<br>suspiciously accessed systems          |
| investigate `cmd.exe` spawning<br>`powershell.exe -NoProfile -Command` in<br>proximity to DAEMON Tools Lite<br>execution or installation events                                           | Asset inventory / service / security<br>telemetry | Identify vulnerable systems, exposure, or<br>suspicious follow-on activity |

### 9.1 Detection Query

```
// Browser and mobile asset-version pivots for CVE-2026-8398 DAEMON Tools Lite embedded malicious code
supply-chain compromise
DeviceProcessEvents
| where Timestamp > ago(30d)
| where ProcessCommandLine has_any ("edge", "msedge", "android", "adb shell dumpsys package", "winget
list")
| project Timestamp, DeviceName, FileName, ProcessCommandLine
| order by Timestamp desc
```

### 9.2 Exposure / Triage Query

```
// Service or exposure triage pivots related to CVE-2026-8398 DAEMON Tools Lite embedded malicious code
supply-chain compromise
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl,
bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

## 10. Threat Hunting

Suggested hunt questions:

- Which Windows systems downloaded or installed DAEMON Tools Lite during the malicious distribution window?
- Did any of those systems execute `DTHelper.exe`, `DiscSoftBusServiceLite.exe`, or `DTShellHlp.exe` after installation?
- Are there historical DNS, proxy, firewall, or EDR records showing contact with `env-check.daemontools[.]cc` or `38.180.107[.]76`?
- Did any suspect hosts spawn `cmd.exe` and `powershell.exe` in a pattern consistent with remote command retrieval and second-stage download?
- Which affected hosts were used by administrators or other privileged users, and what downstream systems did they access after possible exposure?
- Are there unmanaged or user-managed software-install channels that would allow similar signed-utility compromises to bypass enterprise controls in the future?

## 10.1 Hunt Query

```
// Service or exposure triage pivots related to CVE-2026-8398 DAEMON Tools Lite embedded malicious code
supply-chain compromise
DeviceNetworkEvents
| where Timestamp > ago(30d)
| where RemotePort in (80, 443, 8080, 8443, 9443)
| summarize ConnectionCount=count() by DeviceName, InitiatingProcessFileName, RemoteIP, RemoteUrl,
bin(Timestamp, 1h)
| where ConnectionCount > 20
| order by ConnectionCount desc
```

## 11. MITRE ATT&CK Mapping

The following ATT&CK mappings are supportable at a defensive-planning level:

- `T1195 Supply Chain Compromise` — the malware was delivered through official vendor installation packages distributed from the legitimate software website.
- `T1071.001 Application Layer Protocol: Web Protocols` — Kaspersky states the implanted backdoor beacons via HTTP(S) requests to attacker infrastructure.
- `T1059.003 Command and Scripting Interpreter: Windows Command Shell` — the observed second-stage template used `cmd.exe /c` to execute returned commands.
- `T1059.001 Command and Scripting Interpreter: PowerShell` — the published command template used PowerShell to download and launch payloads.
- `T1105 Ingress Tool Transfer` — Kaspersky reports that the delivered command downloaded additional executables from attacker-controlled infrastructure before execution.

These mappings describe public-advisory-supported tradecraft rather than a complete intrusion path proven for every victim endpoint.

## 12. Validation / Lab Testing

This intake review validated the report against official and near-primary public references rather than reproducing the compromise in a lab. Analyst validation completed during this task:

- reviewed the KEV intake item and normalized intake JSON preserved in the report folder
- reviewed the NVD CVE 2.0 record for canonical description, CVSS data, CWE mapping, and KEV required-action fields
- reviewed the CVE Services record published by Kaspersky for CNA metadata, affected-product information, references, and remediation language
- reviewed Disc Soft's official incident post for vendor acknowledgement, containment claims, and safe-version guidance
- reviewed Kaspersky's Securelist write-up for the malicious binaries, timeline, infrastructure, victimology, and staged-payload behavior

No Lost Boys Cyber proof-of-concept execution was performed as part of this intake review.

## 13. Recommended Actions Summary

| Priority | Owner                       | Action                                                                                                                          |
|----------|-----------------------------|---------------------------------------------------------------------------------------------------------------------------------|
| High     | Security / Platform Owners  | Find every system that downloaded or installed DAEMON Tools Lite during the `2026-04-08` to `2026-05-05` exposure window.       |
| High     | Security / Platform Owners  | Replace affected software with `12.6` / `12.6.0.2445` or later and investigate prior execution, not just present version state. |
| High     | SOC / Detection Engineering | Hunt for contact with `env-check.daemontools[.]cc`, downloads from                                                              |

|      |                            |                                                                                                                                                            |
|------|----------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------|
|      |                            | `38.180.107[.]76`, and suspicious<br>`cmd.exe` plus PowerShell activity on<br>exposed Windows hosts.                                                       |
| High | Security / Platform Owners | Prioritize forensic review for endpoints tied<br>to administrators or sensitive business<br>functions because later-stage payloading<br>appears selective. |
| High | Security / Platform Owners | Use this incident to harden software-<br>allowlisting and utility-software<br>governance on Windows fleets.                                                |

## 14. References

13. CISA KEV catalog entry for `CVE-2026-8398`
14. NVD entry for `CVE-2026-8398`
15. CVE Services API record for `CVE-2026-8398`
16. Disc Soft blog, `Security Incident Affecting DAEMON Tools Lite: What We Know So Far`
17. Kaspersky Securelist, `DAEMON Tools software infected — supply chain attack ongoing since April 8, 2026`